S.E LAB 5

Static Code Analysis

Name: Sharvanee Naru

SRN: PES2UG24CS459

GITHUB repo link for lab 5:

https://github.com/sharvanee08/PES2UG24CS459_SE_LAB5

All Labs repo:

https://github.com/sharvanee08/SE_LAB_PES2UG24CS459_SEC_H

BEFORE:

1)Bandit_before

```
Run started:2026-10-14 07:07:12.494607+00:00

Test results:
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'onair2024'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\radio_schedule.py:5:18
4   conn.execute("CREATE TABLE slots (id INTEGER PRIMARY KEY, show TEXT, host TEXT, start_hour INTEGER, minutes INTEGER)")
5   STUDIO_PASSWORD = "onair2024"
6   booked_minutes = 0

--------------------------------------------------
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: .\radio_schedule.py:11:17
10      global booked_minutes
11      conn.execute("INSERT INTO slots (show, host, start_hour, minutes) VALUES ('%s', '%s', %d, %d)" % (show, host, start_hour, minutes))
12      booked_minutes += minutes

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\radio_schedule.py:21:15
20      try:
21          return eval(formula)
22      except Exception:

--------------------------------------------------

Code scanned:
    Total lines of code: 28
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
```

S.E LAB 5

```
--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\radio_schedule.py:21:15
20      try:
21          return eval(formula)
22      except Exception:

--------------------------------------------------

Code scanned:
    Total lines of code: 28
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 1
        Medium: 2
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 2
        High: 1
Files skipped (0):

```

2)flake8_before

flake8_before.txt

```
radio_schedule.py:4:80: E501 line too long (118 > 79 characters)
radio_schedule.py:11:80: E501 line too long (135 > 79 characters)
radio_schedule.py:27:26: E701 multiple statements on one line (colon)
radio_schedule.py:27:80: E501 line too long (110 > 79 characters)

```

3)pylint_before

S.E LAB 5

pylint_before.txt

```
************* Module radio_schedule
radio_schedule.py:4:0: C0301: Line too long (118/100) (line-too-long)
radio_schedule.py:11:0: C0301: Line too long (135/100) (line-too-long)
radio_schedule.py:27:0: C0301: Line too long (110/100) (line-too-long)
radio_schedule.py:1:0: C0114: Missing module docstring (missing-module-docstring)
radio_schedule.py:6:0: C0103: Constant name "booked_minutes" doesn't conform to UPPER_CASE naming style (invalid-name)
radio_schedule.py:9:0: C0116: Missing function or method docstring (missing-function-docstring)
radio_schedule.py:9:0: C0103: Function name "addSlot" doesn't conform to snake_case naming style (invalid-name)
radio_schedule.py:10:4: W0603: Using the global statement (global-statement)
radio_schedule.py:11:17: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
radio_schedule.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
radio_schedule.py:15:0: C0103: Function name "slotLabel" doesn't conform to snake_case naming style (invalid-name)
radio_schedule.py:16:11: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
radio_schedule.py:19:0: C0116: Missing function or method docstring (missing-function-docstring)
radio_schedule.py:19:0: C0103: Function name "overlapFree" doesn't conform to snake_case naming style (invalid-name)
radio_schedule.py:22:11: W0718: Catching too general exception Exception (broad-exception-caught)
radio_schedule.py:21:15: W0123: Use of eval (eval-used)
radio_schedule.py:26:0: C0116: Missing function or method docstring (missing-function-docstring)
radio_schedule.py:26:0: C0103: Function name "morningShows" doesn't conform to snake_case naming style (invalid-name)
radio_schedule.py:27:27: C0321: More than one statement on a single line (multiple-statements)
radio_schedule.py:31:0: C0116: Missing function or method docstring (missing-function-docstring)
radio_schedule.py:31:0: C0103: Function name "removeSlot" doesn't conform to snake_case naming style (invalid-name)
radio_schedule.py:35:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 2.41/10


```

AFTER

1)Bandit_after:

bandit_after.txt

```
Run started:2026-10-14 07:18:04.952940+00:00

Test results:
    No issues identified.

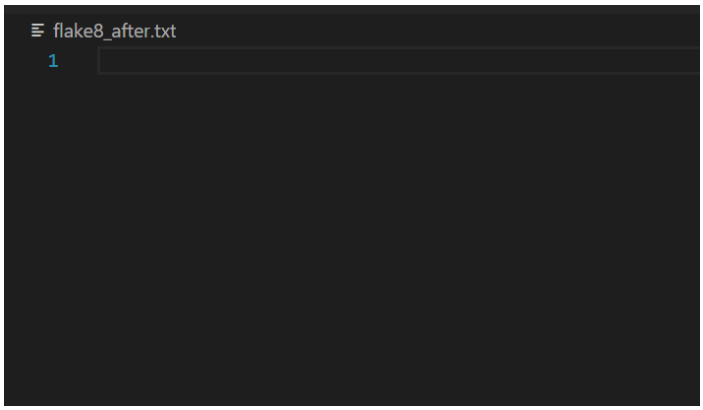
Code scanned:
    Total lines of code: 46
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
Files skipped (0):

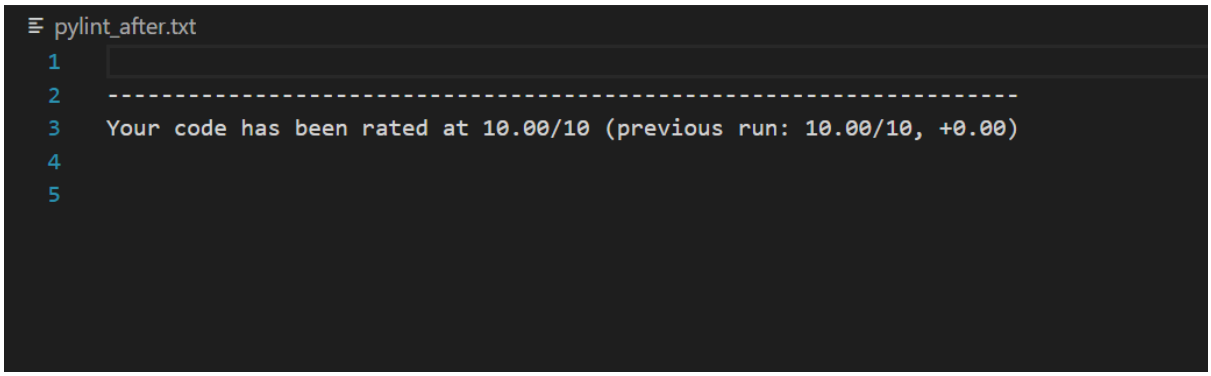
```

S.E LAB 5

2)flake8_after:



3) pylint_after:



Known Issue Table:

Issue	Type	Line(s)	Description	Fix Approach
Hardcoded password	Security	5	Studio password stored directly in the source code.	Removed the unused hardcoded password.
SQL injection risk	Security	11	SQL query constructed using string formatting, allowing potentially unsafe input.	Used parameterized SQL queries with placeholders (?).
Unsafe eval()	Security	21	eval() can execute arbitrary Python expressions.	Replaced it with a direct arithmetic comparison using function parameters.
Missing module docstring	Code quality	1	Module lacked a documentation string.	Added a module docstring.
Invalid naming conventions	Code quality	6, 9, 15, 19, 26, 31	Variable and function names did not follow Pylint naming conventions.	Used a class and snake_case method names; moved booking

S.E LAB 5

				state into an instance attribute.
Missing function docstrings	Code quality	9, 15, 19, 26, 31, 35	Functions lacked documentation strings.	Added docstrings to methods and the main function.
Long lines	Formatting	4, 11, 27	Statements exceeded the configured line-length limits.	Split long statements across multiple lines.
Multiple statements on one line	Formatting	27	An if statement and its return statement appeared on one line.	Used a properly indented multi-line block.
Missing final newline	Formatting	76	File did not end with a newline.	Added a final newline and normalized line endings.